

浅谈信息安全等级保护与ISO27000系列标准的异同

李文兢

(广东机电职业技术学院, 广东 广州 510515)

摘要:信息安全等级保护和ISO27000系列标准是目前国内主流的两个信息安全标准体系,在党政机关及企事业单位运用非常广泛。在建立单位内部信息安全体系的时候往往会遇到需要同时满足两个标准体系要求的难题。该文先简单介绍两个体系的历史及相关标准,然后对这两个标准进行对比研究,从出发点、实施流程、安全分类标准及风险处置方法等方面分析两者之间的差异性及共性。

关键词:信息安全等级保护;ISO27000;信息安全标准

中图分类号:TP311 **文献标识码:**A **文章编号:**1009-3044(2012)20-4841-02

Integrated Application of The Classified Protection and ISO27000 Series

LI Wen-jing

(Guangzhou South China Information Technology Security Evaluation Center, Guangzhou 510050, China)

Abstract: The Classified Protection and ISO27000 series are the two current popular security standards in China, which are extensively applied by the Party and government departments, enterprises and institutions. Meeting the requirements of both standards is a usual problem in establishing internal security system. The essay introduces the history and relative standards of two system, and makes a comparative study of the two standards, analyses their differences and similarity in purpose, implementation process, security classification standard and risk handling and summaries the problems in implementing the two standards.

Key words: the classified protection; ISO27000; information security standard

从第一个信息安全评估标准(TCSEC)发布以来,信息安全相关标准经过二十多年的发展,在体系建设与工程等方面都有不同的标准出现,促进了信息安全工作的规范化和发展。ISO27000系列标准作为国际知名的信息安全管理标准,已在全球多个国家应用和实施。信息安全等级保护制度从1994年提出,从引进国外标准到提出符合国情的“分级保护”制度,标准体系越来越成熟,可行性也逐步加强。2006年6月公安部、国家保密局、国家密码管理局和国信办发布了《关于开展信息安全等级保护试点工作的通知》,试点单位包括北京、山西、上海等十三个省、市、自治区以及中联部、中组部、航天科技集团等三个部门^[1]。信息安全等级保护在保护国家安全、公共利益和社会秩序等方面扮演了至关重要的角色。信息安全工作者在实际工作中经常需要同时按照两种标准开展相关工作。下面笔者将从概念、出发点、分级标准及安全分类等角度来分析两者的异同点。

1 信息安全等级保护制度和ISO 27000系列标准的概念

1.1 信息安全等级保护制度

我国于1999年发布了国家标准GB17859《计算机信息安全保护等级划分准则》,成为建立安全等级保护制度、实施安全等级管理的重要基础性标准。目前已发布GB/T22239、GB/T22240、GB/T20270、GB/T 20271、GB/T 20272等配套标准10余个,涵盖了定级指南、基本要求、实施指南、测评要求等方面。GB17859的核心思想是对信息系统特别是对业务应用系统安全分等级、按标准进行建设、管理和监督。国家对信息安全等级保护工作运用法律和技术规范逐级加强监管力度,保障重要信息资源和重要信息系统的安全^[2]。

1.2 ISO 27000系列标准

ISO 27000起源于英国的BS 7799标准系列,其中ISO 27001是“信息安全管理要求”(Specification for Information Security Management Systems),是在组织内部建立信息安全管理体系统一套规范,其中详细说明了建立、实施、运行、监视、评审、保持和改进信息安全管理体系统模型和要求,可用来指导相关人员应用ISO 27002,其最终目的,通过规范的过程,建立适合组织实际要求的信息安全管理体系^[3]。ISO 27002提出了在组织内部启动、实施、保持和改进信息安全管理指南和一般原则,包括11个要素,39个控制目标和133种控制措施^[4];

2 等级保护系列标准与ISO/IEC27000系列标准的对比分析

从信息安全等级保护制度和ISO 27001系列标准的内容来看,两者既有相同的地方又有不同之处,下面就分别分析两者之间的差异性及共性。

2.1 两者的差异性

收稿日期:2012-06-15

作者简介:李文兢(1977-),男,广东高州人,工学硕士,讲师,研究方向为信息安全体系建设,信息安全管理效果评价方法及指标体系。

本栏目责任编辑:冯蕾

网络通讯及安全 4841

2.1.1 两者的出发点不同

信息安全等级保护制度是以国家安全、社会秩序和公共利益为出发点,从宏观上指导全国的信息安全工作,目的是构建国家整体的信息安全保障体系,ISO 27000系列标准是以保证组织业务的连续性,缩减业务风险,最大化投资收益为目的,目的是保证组织的业务安全。

2.1.2 两者的分级标准的差异

等级保护实施首先是定级问题,针对不同的级别,提出了不同的等级安全要求;ISO 27000系列标准的第一步是风险评估,根据资产的价值和所面临的风险进行分类,然后针对不同的风险选择相应的风险处置措施。虽然都是从分级或分类入手,但是两者的分级标准不同。等级保护的分级主要考虑四个方面的风险,即信息系统遭到破坏后对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益所造成的影响,按照影响程度大小分为五级,等级保护的分级以组织外部影响为依据。而ISO 27000系列标准的分级是根据资产、威胁、脆弱点、影响、风险等各个因素之间的关系,采取定量或者定性的方法进行分级分类,采取何种风险处置措施,也是组织根据自己对风险的接受程度而决定。ISO 27000标准以组织内部业务影响为依据。

2.1.3 两者的安全分类的差异

等级保护和ISO 27000系列标准都从技术和管理两个方面提出了信息安全的要求。等级保护有10个方面的要求,技术方面有:物理安全、网络安全、主机系统安全、应用安全、数据安全,管理方面有:安全管理机构、安全管理制度、人员安全管理、系统建设管理、系统运维管理;而ISO 27001标准有11个方面,分别是:安全策略、组织信息安全、资产管理、人力资源安全、物理和环境安全、通信和操作管理、访问控制、信息系统获取开发和维护、信息安全事件管理、业务连续性管理、符合性。而且两者在各个大分类下面又规定了若干的小项目。

2.1.4 两者实施流程的差异

等级保护首先对信息系统进行定级,定级之后再结合不同等级的安全要求进行安全需求分析。在定级之前,首先要对信息系统进行描述,主要包括系统边界、网络拓补、设备部署等,对于大型的信息系统要在综合分析的基础上进行划分,确定可作为定级对象的信息系统个数。信息系统的定级由受侵害客体和对客体的侵害程度两个因素决定,通过综合判定客体的受侵害程度来确定系统的安全保护等级。安全等级确定之后,从信息系统安全等级保护基本要求中选择相应的等级评价指标,通过现场观察、询问、检查、测试等方式进行评估,确定信息系统安全保护的基本需求。对于有特殊保护要求的信息系统重要资产,其安全需求分析则采用风险评估的方法来进行。

ISO27000系列标准通过风险评估来识别风险和威胁,进而确定组织的信息安全需求,选择风险控制措施。在风险评估之前首先根据组织业务特征、资产和技术来确定ISMS范围和ISMS方针,然后选择使用于组织的风险评估方法,识别ISMS范围内的资产、资产所有者、资产的威胁、可能被资产利用的脆弱点、资产损失可能造成的影响,对风险进行分析和评价,评估安全失效可能造成的影响及后果、威胁和脆弱性发生的可能性,进而确定风险的等级。整个风险评估的过程就是对组织信息安全需求分析的过程。

2.2 两者的共性

尽管两者在很多内容上都存在着差异,但是两者也有很多共同之处。

2.2.1 两者风险处理思想相同

信息安全没有百分之百的安全,所以无论是等级保护还是ISO 27001标准都在实施之前强调分级分类,只有找出信息安全保护的重点,才能把有限的资源投入到信息安全的關鍵部位,做到统筹安排,而不是“眉毛胡子一把抓”。

2.2.2 两者在安全分类上的共同点

虽然等级保护和ISO 27001标准在安全措施分类上存在差别,但是很多项目都是共通的,如等级保护对“网络安全”的要求,就分别体现在ISO 27001标准的“访问控制”、“通信和操作管理”、“信息安全事件管理”等各个项目中。无论是技术还是管理上的安全措施,两者都或多或少的存在共性。

2.2.3 两者是宏观与微观,相辅相成的关系

信息系统都是分布于各个组织内部,组织内部的信息安全是国家整体信息安全的基础,网络的互联和信息的共享,一个组织内部的信息系统遇到风险业务中断,就可能导致一系列的信息安全连锁反应,国家整体的信息安全水平体现在每个组织的信息安全能力上。同样组织的信息安全也受到整体外部信息网络环境的影响,组织的风险来自内部也来自外部,一个组织要和外界互联共享就必然面临风险,很难想象一个组织能够在一个不安全的信息网络环境中安然无恙。

3 结论

该文通过等级保护与ISO27000系列标准两个信息安全标准体系的对比,详细描述了两者在出发点、分级标准、安全分类标准、实施流程及风险处理思想方面的共性与差异。笔者在长期的信息安全工作实践中根据该文的思路进行相关机构单位的信息安全体系建设工作,并取得良好的效果。

参考文献:

- [1] 郭启全.我国信息安全等级保护工作全面开展[J].信息技术与标准化,2007.9:4-7.
- [2] GB17859-1999,计算机信息系统安全保护等级划分准则[S].
- [3] International Organization for Standardization.Information technology Security techniques Information security management systems-Requirements ISO/IEC27001[S].2005.10.
- [4] International Organization for Standardization.Information technology Security techniques Code of practice for Information security management ISO/IEC 17799:2005[S].2005.6.